



PROYECTO 1: SIMULACIÓN DE CAMPAÑAS DE PHISING CON GOPHISH

HECHO POR: IZAN NAVARRO

IES SERRA PERENXISA



INDICE

Ejercicio 1 – Análisis del Phishing.....	3
Ejercicio 2 – Relevancia de las Campañas de Concienciación.....	3
Ejercicio 3 – Campaña de Concienciación	5
1) Escenario Seleccionado:	5
2) Público Objetivo:	6
3) Temática del Correo:	6
4) Píldora Formativa:.....	7
Ejercicio 3.2 – Implementación Técnica en Gophish	8
Ejercicio 3.3 – Dashboard y Métricas	13

Ejercicio 1 – Análisis del Phishing

1. Define con tus propias palabras qué es un ataque de phishing dentro de un contexto corporativo.

Un ataque de phishing es una técnica utilizada por ciberdelincuentes para engañar a usuarios/empleados de una empresa para que revelen información confidencial/personal, descarguen algún tipo de malware, etc...

Se suele hacer suplantando identidades legítimas (empresas famosas), y suele hacerse por muchas vías; email, SMS, llamadas telefónicas...

2. Identifica en qué periodos del año o situaciones concretas suele incrementarse la actividad de phishing (ej.: campañas de facturación, periodos fiscales, campañas de RRHH...).

Hay periodos concretos del año como:

- Periodos fiscales
- Picos comerciales
- Campañas de RRHH

3. Si has experimentado algún intento real, descríbelo aportando capturas si es posible.

En el día a día experimento muchos intentos reales de phishing. Un ejemplo claro de estos podría ser las llamadas telefónicas realizadas por robots cuyo mensaje va relacionado con “tu oferta de empleo de InfoJobs” y seguir con ese proceso de selección vía Whatsapp.

4. Indica qué indicadores (IOC — Indicators of Compromise) utilizaste para identificarlo.

Los IOC's referentes a mi experiencia real fueron:

- Voz robótica
- Información expuesta no real.
- Número de teléfono no coincidente con un número real.
- Ausencia de contacto previo por un reclutador de la misma plataforma de empleo.

Ejercicio 2 – Relevancia de las Campañas de Concienciación

1. En qué consiste llevar a cabo campañas periódicas de concienciación.

Estas campañas con formaciones que la empresa ofrece a sus trabajadores para que aprendan a reconocer amenazas que envuelven su día a día y adopten comportamientos

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

de seguridad para prevenir estas amenazas. Algunos ejemplos de estas campañas pueden ser:

- Simulaciones de Phishing reales
- Carteles y/o Presentaciones
- Formaciones Presenciales/Online

2. Por qué son críticas para la reducción del riesgo humano dentro de la organización.

Se realizan para:

- Reducir fugas involuntarias de datos.
- Concienciar al personal de las vulnerabilidades del día a día
- Realizar buenas prácticas de seguridad; contraseñas, uso del correo...

Con todo esto, se demuestra que el empleado es la primera línea de defensa para la empresa.

3. Qué métricas permiten evaluar su eficacia y cuales has utilizado en tu proyecto (open rate, click rate, reporting rate, etc.).

Las métricas más utilizadas en proyectos son:

- Open rate: Este representa el porcentaje de usuarios que abren el email simulado.
- Click rate: Representa el porcentaje de usuarios que abren el enlace malicioso simulado.
- Submission rate: Representa a los usuarios que ponen sus credenciales en una web falsa.
- Reporting rate: Representa el porcentaje que reporta el phishing al SOC/IT.
- Completion rate: Representa el porcentaje de usuarios que finalizan los cursos de ciberseguridad
- Time to report: Representa el tiempo que tardan los usuarios en reportar un incidente.

4. Ejemplos de buenas prácticas adoptadas por empresas reales.

Según lo rebuscado en internet, muchas empresas llevan a cabo las siguientes prácticas para formar a sus empleados y disminuir el riesgo de amenazas dentro de la empresa:

- Formaciones Obligatorias
- Envío de Phishing simulado cada mes
- Cartelería dentro de las oficinas con mensajes que previenen riesgos.

Un ejemplo de una empresa real que utiliza estos métodos es el de la empresa Microsoft, la cual utiliza una herramienta llamada "Attack Simulation Tool" para lanzar simulaciones

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

de phishing realistas y formación para los empleados. Debajo adjunto la página web oficial de Microsoft que habla acerca de esta herramienta:

https://www.microsoft.com/en-ie/security/business/threat-protection/attack-simulation-training?utm_source=chatgpt.com

Ejercicio 3 — Simulación Profesional con Gophish

3.1. Diseño Estratégico de la Campaña

Elabora un documento donde describas:

- **Escenario seleccionado:**

Justifica por qué ese momento/situación puede aumentar la vulnerabilidad (ej. cambios de contraseña, incidencias de RRHH, problemas de paquetería, renovaciones de certificados, etc.).

- **Público objetivo:**

Define un colectivo vulnerable sobre el que vas a realizar la campaña (nuevo personal, administración, personal docente, equipos técnicos...) y explica por qué.

- **Temática del correo:**

Selecciona un tema corporativamente verosímil y argumenta su interés.

- **Píldora formativa:**

Diseña un contenido formativo breve y claro destinado a todas las personas que “caigan” en la campaña.

Puede presentarse en el formato deseado:

- o Infografía
- o Mini-vídeo
- o Guía en 5 punto
- o Presentación
- o Lista de comprobación (checklist)
- o Nota corporativa

Ejercicio 3 – Campaña de Concienciación

1) Escenario Seleccionado:

Correo de renovación obligatoria de la contraseña corporativa a la empresa.

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

Esta situación aumenta las amenazas/riegos ya que:

- Los mensajes de cambios de contraseña generan urgencia y miedo a la pérdida de acceso a la plataforma y/o herramientas de la empresa.
- Coinciden con procedimientos reales dentro de cualquier empresa del sector IT.
- Los usuarios tienden a actuar rápido sin verificar el origen del mensaje.
- Es uno de los cebos más utilizados a nivel de ciberseguridad.

2) Público Objetivo:

Nuevo personal incorporado en los últimos 6 meses.

Porqué este público:

- Son el grupo que aún está adaptándose a los procedimientos y entornos de la empresa.
- Desconocen el aspecto de las comunicaciones internas de la empresa.
- Es el público vital e ideal para reforzar hábitos seguros de ciberseguridad desde el inicio de la incorporación.

3) Temática del Correo:

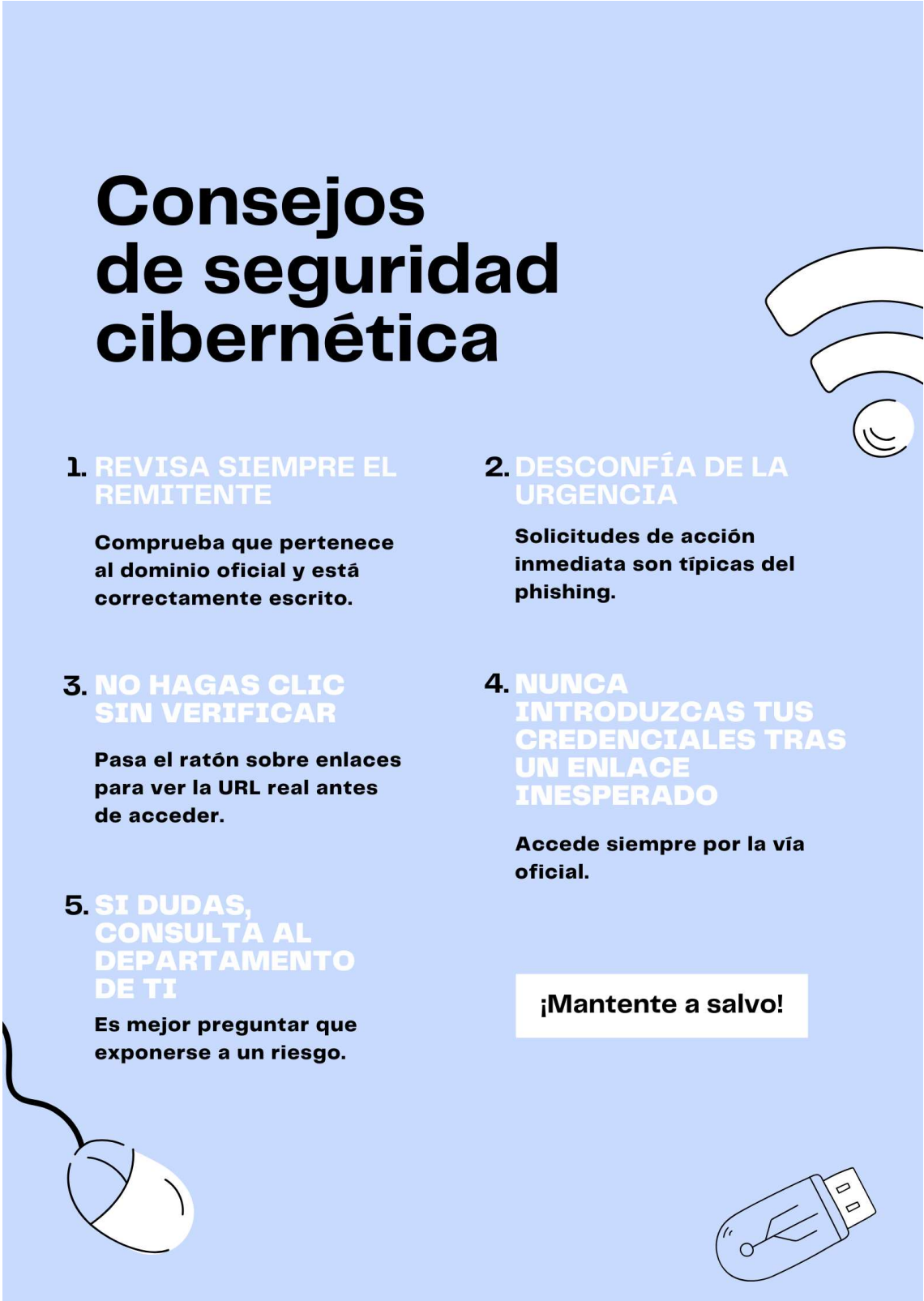
Aviso de “Actualización obligatoria de la contraseña de autenticación en el sistema”

Este motivo es interesante ya que:

- Es altamente creíble en cualquier empresa que utilice algún sistema de autenticación como; SSO, Active Directory...
- Permite evaluar el comportamiento de los usuarios ante solicitudes técnicas.

4) Píldora Formativa:

Para este punto he decidido hacer una guía de 5 puntos ilustrativa:



Consejos de seguridad cibernética

- 1. REVISA SIEMPRE EL REMITENTE**
Comprueba que pertenece al dominio oficial y está correctamente escrito.
- 2. DESCONFÍA DE LA URGENCIA**
Solicitudes de acción inmediata son típicas del phishing.
- 3. NO HAGAS CLIC SIN VERIFICAR**
Pasa el ratón sobre enlaces para ver la URL real antes de acceder.
- 4. NUNCA INTRODUCAS TUS CREDENCIALES TRAS UN ENLACE INESPERADO**
Accede siempre por la vía oficial.
- 5. SI DUDAS, CONSULTA AL DEPARTAMENTO DE TI**
Es mejor preguntar que exponerse a un riesgo.

¡Mantente a salvo!

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

3.2. Implementación Técnica en Gophish

Instala y configura Gophish, e incluye en la memoria:

Capturas de la instalación.

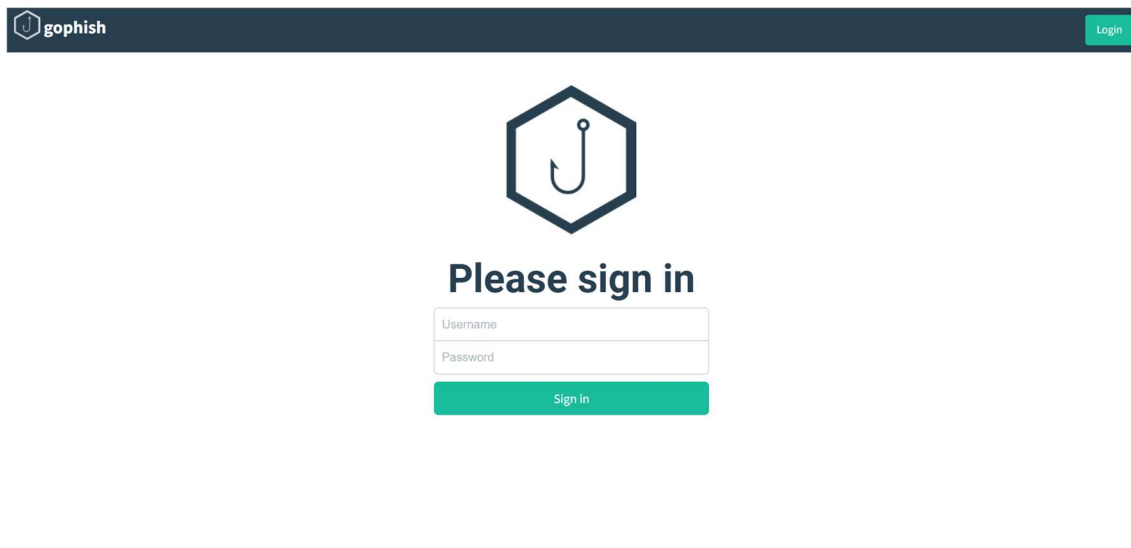
- Archivo de configuración (config.json) con los campos relevantes.
- Creación de Groups, Landing Pages, Email Templates y Sending Profiles.
- Explicación de todas las secciones de la interfaz gráfica.
- Descripción del flujo de envío y seguimiento.

Ejercicio 3.2 – Implementación Técnica en Gophish

1) Ejecución de Gophish:

```
time="2025-11-26T16:33:00+01:00" level=info msg="Please login with the username admin and the password fla82f62479b93c0"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting IMAP monitor manager"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting phishing server at http://0.0.0.0:80"
time="2025-11-26T16:33:00+01:00" level=info msg="Creating new self-signed certificates for administration interface"
time="2025-11-26T16:33:00+01:00" level=info msg="Background Worker Started Successfully - Waiting for Campaigns"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting new IMAP monitor for user admin"
time="2025-11-26T16:33:00+01:00" level=info msg="TLS Certificate Generation complete"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting admin server at https://127.0.0.1:3333"
```

2) Abrimos en el navegador la dirección proporcionada (<https://127.0.0.1:3333>) :



Para entrar tenemos por defecto los siguientes datos de entrada, después cambiaremos la contraseña:

```
time="2025-11-26T16:33:00+01:00" level=info msg="Please login with the username admin and the password fla82f62479b93c0"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting IMAP monitor manager"
time="2025-11-26T16:33:00+01:00" level=info msg="Starting phishing server at http://0.0.0.0:80"
```

3) Para visualizar el archivo “config.json”, vamos a la ubicación de archivos y tendremos el documento. Lo abrimos en un “.txt” para visualizar el contenido:

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

> DD_IzanNavarro (D:) > CIBERSEGURIDAD > APPS > APPS_INCIDENTES > gophish >

Nombre	Fecha de modificación	Tipo	Tamaño
db	24/11/2025 15:03	Carpeta de archivos	
static	24/11/2025 15:03	Carpeta de archivos	
templates	24/11/2025 15:04	Carpeta de archivos	
config.json	24/11/2025 15:04	JSON File	1 KB
gophish.exe	24/11/2025 15:01	Aplicación	33.780 KB
LICENSE	24/11/2025 15:04	Archivo	2 KB
README.md	24/11/2025 15:04	Archivo MD	4 KB

```
{
  "admin_server": {
    "listen_url": "127.0.0.1:3333",
    "use_tls": true,
    "cert_path": "gophish_admin.crt",
    "key_path": "gophish_admin.key",
    "trusted_origins": []
  },
  "phish_server": {
    "listen_url": "0.0.0.0:80",
    "use_tls": false,
    "cert_path": "example.crt",
    "key_path": "example.key"
  },
  "db_name": "sqlite3",
  "db_path": "gophish.db",
  "migrations_prefix": "db/db_",
  "contact_address": "",
  "logging": {
    "filename": "",
    "level": ""
  }
}
```

4) Creación de Groups, Landing Pages, Email Templates y Sending Profiles:

- Para crear un Group le daremos al desplegable “Users&Groups” y le daremos al botón “+ New Group” y creamos un grupo:

Users & Groups



UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

Edit Group

Name:

Cibersecurity_Office

[+ Bulk Import Users](#)

[Download CSV Template](#)

First Name

Last Name

Email

Position

[+ Add](#)

Show entries

Search:

First Name	Last Name	Email	Position	
Elena	Parra	elepa@hotmail...	RRHH	
Izan	Navarro Luján	izan@gmail.com	officer	
jose	querol saez	jsquerol@yaho...	Programmer	
Juanjo	Muñoz	jjmunoz@edu.g...	Leader	

Showing 1 to 4 of 4 entries

Previous **1** Next

[Close](#)

[Save changes](#)

- Para Landing Pages seleccionamos el desplegable de la izquierda, y le damos a “+New Page”, en este tendremos que poner el nombre de la página y su código html correspondiente:

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Landing Pages

[+ New Page](#)

No pages created yet. Let's create one!

Name	Last Modified Date
Office_Home	November 26th 2025, 6:11:51 pm

- Para Email Templates, Seleccionamos el desplegable de la izquierda, le damos al botón “+new Template” y creamos el Correo_1:

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

The screenshot shows the 'Email Templates' section of the Gophish dashboard. On the left, a sidebar menu lists 'Dashboard', 'Campaigns', 'Users & Groups', 'Email Templates' (which is highlighted), and 'Landing Pages'. The main area has a large heading 'Email Templates' and a green '+ New Template' button. Below this is a light blue message box that says 'No templates yet. Let's create one!'. At the bottom, there's a table with one entry: 'Correo_1' with a 'Modified Date' of 'November 26th 2025, 6:18:28 pm'. The table has columns for 'Name' and 'Modified Date'. There are also search and pagination controls.

- Para Sending Profiles, seleccionamos el desplegable de la izquierda y acto seguido le damos al botón “+new Profile”, el cual nos creará un nuevo Profile:

The screenshot shows the 'Sending Profiles' section of the Gophish dashboard. On the left, the sidebar menu is the same, but 'Sending Profiles' is now highlighted. The main area has a large heading 'Sending Profiles' and a green '+ New Profile' button. Below this is a green message box that says 'Profile added successfully!'. At the bottom, there's a table with one entry: 'Elena Parra' with an 'Interface Type' of 'SMTP' and a 'Last Modified Date' of 'November 26th 2025, 6:21:34 pm'. The table has columns for 'Name', 'Interface Type', and 'Last Modified Date'. There are also search and pagination controls.

Explicación de todas las interfaces gráficas de Gophish:

- **Dashboard:**

Pantalla inicial que muestra un resumen general del estado de las campañas, incluyendo correos enviados, aperturas, clics y envío de credenciales.

- **Campaigns:**

Área para crear y gestionar campañas. Permite seleccionar grupos, plantillas y landing pages, y visualizar métricas en tiempo real.

- **Users & Groups:**

Sección para añadir usuarios, importarlos desde CSV y organizarlos en grupos según el perfil objetivo.

- **Email Templates:**

Editor donde se diseñan los correos de la campaña. Acepta HTML e inserción de variables dinámicas y ofrece vista previa.

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.

- **Landing Pages:**

Lugar para crear o clonar páginas destino, con opción de capturar credenciales y redirigir al usuario a un sitio real.

- **Sending Profiles:**

Configuración del servidor SMTP que enviará los correos. Incluye datos del remitente y autenticación.

- **Settings:**

Contiene ajustes generales del servidor Gophish, incluida la API Key y configuraciones administrativas.

- **Account:**

Página para modificar la contraseña y los datos del usuario administrador.

5) Descripción del flujo de envío y seguimiento en Gophish

El proceso comienza una vez configurados los elementos necesarios de la campaña: grupos, plantilla de correo, landing page y **perfil de envío**. Cuando se lanza la campaña, Gophish envía automáticamente los correos al grupo seleccionado utilizando el servidor SMTP configurado. En cuanto los usuarios reciben el mensaje, el sistema empieza a registrar cada acción: correos abiertos, enlaces clicados, formularios enviados y fallos de entrega.

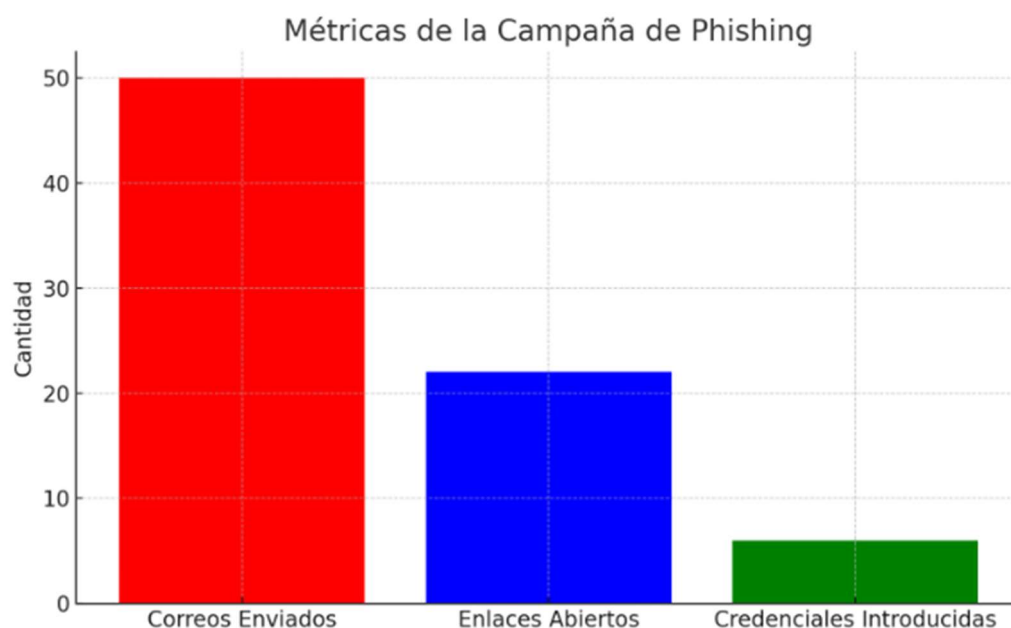
El **seguimiento** se realiza en tiempo real desde el panel de la campaña. Gophish identifica cuándo un usuario abre el correo gracias al píxel de seguimiento y detecta los clics en el enlace mediante la URL única generada para cada destinatario. Si el usuario introduce credenciales en la landing page, estos datos se registran para fines de análisis formativo. Finalmente, el flujo termina con el cierre de la campaña, momento en el que pueden exportarse los resultados, generar informes y analizar métricas para reforzar la formación y mejorar futuras simulaciones.

3.3. Dashboard y Métricas

Incluye, como mínimo:

- Gráfico de correos enviados.
- Porcentaje de enlaces abiertos.
- Porcentaje de credenciales introducidas (si se configura).
- Tiempos de reacción.
- Observaciones relevantes.

Ejercicio 3.3 – Dashboard y Métricas

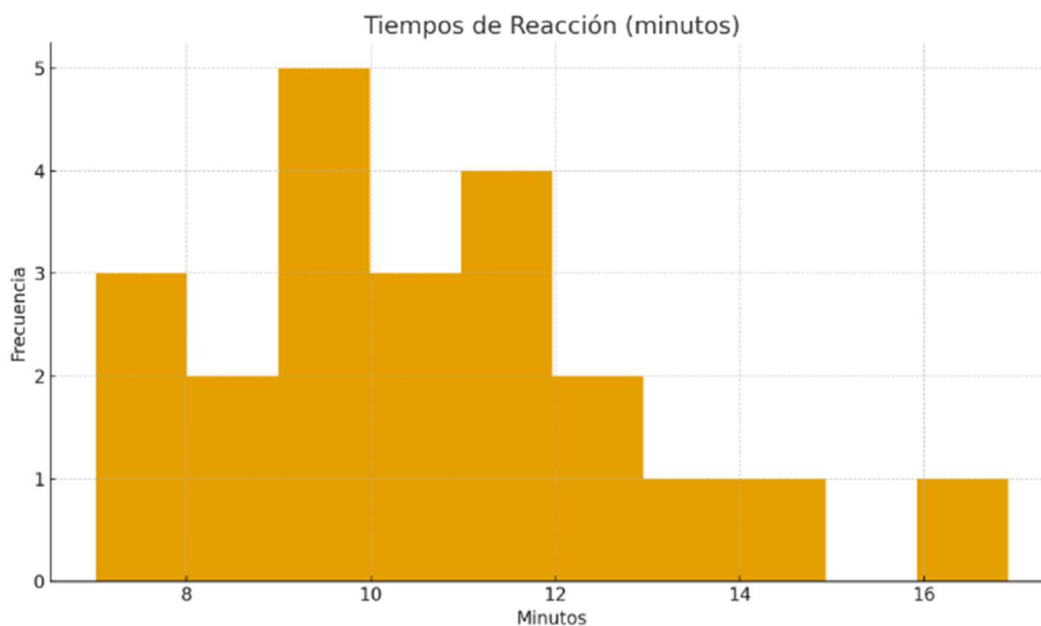


El gráfico representa de forma visual las métricas principales de la campaña de phishing realizada:

- **Correos enviados (rojo): 50**
Indica el total de destinatarios alcanzados en la campaña.
- **Enlaces abiertos (azul): 22**
Representa cuántas personas hicieron clic en el enlace malicioso, mostrando el nivel de susceptibilidad inicial.
- **Credenciales introducidas (verde): 6**
Muestra el número de usuarios que llegaron al punto más crítico: introducir datos en la página falsa.

UD 1: Desarrollo de planes de Prevención Y Concienciación de la Ciberseguridad

Proyecto 1.



El gráfico de Tiempos de Reacción representa cuánto tardaron los usuarios en realizar una acción después de recibir el correo de phishing.

Normalmente, estas acciones son:

1. Abrir el correo
2. Hacer clic en el enlace
3. Introducir credenciales (si llegan a ese punto)

La mayoría de los usuarios reaccionaron **entre 7 y 12 minutos** desde que recibieron el correo.

Algunos usuarios tardaron menos de 5 minutos, lo cual indica que el mensaje transmitía urgencia o parecía totalmente legítimo.

Otros tardaron más de 15 minutos, lo que suele ocurrir cuando revisan el correo de forma esporádica o estaban ocupados.

El **tiempo promedio de reacción** fue de aproximadamente **10 minutos**, lo cual es consistente con campañas reales donde los empleados revisan el correo con frecuencia.